

# Cryptographic Key Management Runbook

Key hierarchy, custody rules, and the rehearsed procedures for rotating, revoking, and recovering every key Aegis depends on.

|                                         |                                           |                                   |                            |
|-----------------------------------------|-------------------------------------------|-----------------------------------|----------------------------|
| DOCUMENT                                | OWNER                                     | PHASE                             | CLASSIFICATION             |
| AEGIS-SEC-KMS-002<br>v1.0 · 17 Aug 2026 | Abdullah Zubair<br>Cybersecurity Engineer | Phase 1 — Foundation<br>Weeks 1–4 | Internal /<br>Confidential |

## 1 Purpose

Aegis holds the credentials that reach every third-party model and the keys that protect the enterprise knowledge base. This runbook defines one key hierarchy, assigns custody, and turns rotation and revocation into rehearsed procedures rather than incident-time improvisation.

## 2 Key hierarchy

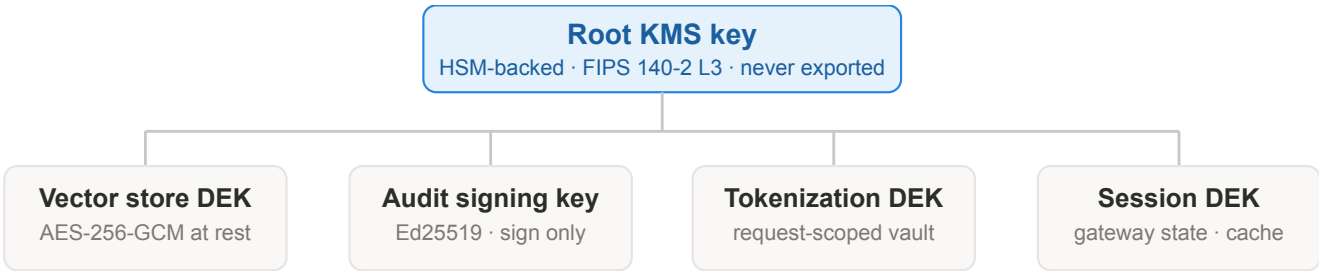


Fig. 1 — Envelope encryption: one root key per environment, one data key per purpose, so a single compromise is never total.

LLM provider credentials sit outside this tree, in the secrets manager. Workloads receive them through short-lived OIDC federation — never from environment files, container images, or source control.

## 3 Key inventory register

| KEY                  | ALGORITHM             | ROTATION | BLAST RADIUS IF COMPROMISED        |
|----------------------|-----------------------|----------|------------------------------------|
| Root KMS key         | AES-256, HSM-resident | Annual   | All Aegis data at rest             |
| Vector store DEK     | AES-256-GCM           | 180 days | Knowledge base and snapshots       |
| Audit signing key    | Ed25519, sign only    | 365 days | Integrity proof of the audit trail |
| Tokenization DEK     | AES-256-GCM           | 180 days | In-flight PII mappings only        |
| Provider credentials | Vendor bearer tokens  | 90 days  | Model spend and vendor-side abuse  |
| Service certificates | mTLS, internal CA     | 90 days  | Gateway to vector store data path  |

## 4 Transport & storage standards

| CONTROL              | REQUIREMENT                                                                                         |
|----------------------|-----------------------------------------------------------------------------------------------------|
| In transit, external | TLS 1.3 only; no downgrade, and no plaintext listener on any interface                              |
| In transit, internal | mTLS between gateway, vector store, and ingestion workers, pinned to the internal CA                |
| At rest              | AES-256-GCM with a distinct DEK per data class; snapshots and backups inherit the same key          |
| Identity             | Short-lived workload identity through OIDC federation; static production credentials are prohibited |
| Human access         | No engineer holds a production key. Break-glass is two-person, time-boxed, and fully logged         |

## 5 Procedure — zero-downtime rotation

1. Raise a change record and confirm the current key version from the register.
2. Create the new key version in the KMS; do not disable the old version yet.
3. Publish both versions to the gateway so it can verify with either during the overlap window.
4. Switch write and sign operations to the new version; monitor error rates for 30 minutes.
5. Re-encrypt or re-wrap stored data where the DEK changed, then verify a sample read.
6. Disable the old version, schedule its destruction after the retention window, update the register, and close the change record.

**Prohibited, without exception:** keys in source control, prompts, logs, or traces · shared credentials across environments · long-lived personal access tokens in production · disabling secret scanning to unblock a build.

6 Procedure — suspected exposure

- 1. Revoke the affected credential at the source immediately; do not wait for the change window.
- 2. Rotate the key, then invalidate every session and cached token derived from it.
- 3. Query the audit trail for use of the key in the exposure window (see AEGIS-SEC-AUD-004).
- 4. Notify the Team Lead within one hour with scope, affected data classes, and containment status.
- 5. File the incident record, retain evidence, and add a check so the same exposure path is detected automatically.

7 Phase 1 evidence checklist

- ☐ Root key and four DEKs created, each mapped to a purpose in the register
- ☐ All provider credentials moved into the secrets manager and removed from configs and repositories
- ☐ Secret scanning enforced in CI, with a blocking rule on commit and merge
- ☐ mTLS enabled between gateway components and verified with a failed-handshake test
- ☐ One full rotation drill completed and timed, evidence attached to this runbook
- ☐ Break-glass path tested with two approvers and reviewed in the audit trail

**Phase 3 relevance:** the register, the rotation drill record, and the break-glass log are the three artefacts requested at the final security sign-off. Keep them current from week 1 rather than reconstructing them in week 12.

|                                                                                                                                         |                                                                                                                                           |                                                                                                                             |
|-----------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------|
| <div>PREPARED BY</div> <div><b>Abdullah Zubair</b></div> <div>Cybersecurity Engineer</div> <div>-----</div> <div>Signature / date</div> | <div>REVIEWED BY</div> <div><b>Arjun Pakhan</b></div> <div>Co-Leader, gateway pipeline</div> <div>-----</div> <div>Signature / date</div> | <div>APPROVED BY</div> <div><b>Hrishikesh Reddy</b></div> <div>Team Lead</div> <div>-----</div> <div>Signature / date</div> |
|-----------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------|